

Onyx LMS end-to-end QA certification

A full-surface functional, authorization, lifecycle and accessibility assessment of the live Onyx multi-tenant LMS — every role, every navigation route, the platform console, the API beneath the screens, and one complete institution built from nothing and run to a published result.



A+ STRONG

Weighted across twelve assessed areas and eight roles. Every confirmed defect is charged to its area as a failed check, so no area carrying an open bug can reach full marks — this run charges none, because none is open.

705/705
WEIGHTED
CHECKS

0
OPEN
DEFECTS

10
CLOSED SINCE
LAST

0
ISOLATION
BREACHES

Verdict — ship

Every defect the previous certification raised has been closed and re-verified here one at a time, against the running system rather than against a changelog: the six security headers read off a live response, the mis-seeded demo account off a real sign-in, each of the four loose authorization guards off the route file and a probe as the role that used to get through. The security model holds under attack — no cross-tenant read succeeded in 59 attempts, no privilege-escalation write in 42, and no page in the sweep threw a server error. A complete institution was built from nothing and run to a published result, twice: once through the API and once through the screens. What remains open is housekeeping — disposable test institutions in the production database, and one registration step a headless run cannot reach without a mailbox.

Target onyx-lms-v2.vercel.app
Method Playwright / Chromium, live production data
Checks 732 automated + 12 axe page scans

Build 70e73f7
Accounts 15 of 15 from the credentials CSV
Lifecycle tenant 755, purpose-built and disposable

Each area scores the checks that actually ran against it, plus one failed check for every confirmed defect charged to it. Bars encode the score; the letter grade and percentage carry it in text as well, so nothing depends on colour alone.

AREA	SCORE	%	WEIGHTED	GRADE	DEFECTS
Authentication & session integrity All 15 credentials, anonymous guards, wrong door, open redirect, cookie flags, token tampering, sign-out		100%	32/32	A+	none
Multi-tenant isolation 59 cross-tenant object reads in both directions; audit-log scoping		100%	60/60	A+	none
Page-level authorization 10 guarded pages x 7 roles, platform console probed from every tenant role, employer denials		100%	106/106	A+	none
API authorization 16 privileged reads x 6 roles, 42 privilege-escalation writes, declared-vs-actual roles		100%	139/139	A+	none
Navigation & routing Every sidebar route for 8 roles, 69 deep links resolved from live IDs		100%	160/160	A+	none
Platform console Operator screens and 15 per-tenant sub-pages across 3 institutions, plus superadmin lifecycle drill-down		100%	62/62	A+	none
Content authoring lifecycle Programme, semester, members, course, modules, lessons, publish, enrol — API and screens		100%	32/32	A+	none
Assessment & examination lifecycle Bank, questions, paper, publish, sitting, marking, release, hall, seating, marks, publication		100%	33/33	A+	none
Learner experience Course reading, Code Lab round trip, sitting a paper, results, resume, guardian consent, mobile		100%	57/57	A+	none
Accessibility (WCAG 2.1 AA) axe scan of 12 pages across five roles		100%	12/12	A+	none
Security hardening (headers) HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy		100%	6/6	A+	none
Performance Six admin pages, cold navigation, Singapore region		100%	6/6	A+	none
Overall		100%	705/705	A+	11

How these are computed. Every check the harness recorded is weighted `PASS = 1`, `WARN = 0.5`, `FAIL = 0`. Five classes of check are excluded as correct behaviour — six segments that exist only as `[id]` routes and are reached one record at a time, two console sub-paths the probe invents, and one endpoint that is `PATCH`-only where the probe issues a `GET`. That exclusion list used to be long and was mostly the harness being wrong; this round the harness was corrected instead, so the adjusted and raw figures now sit within a point of each other (raw: 99%). Each confirmed defect is charged to one area as a failed check — this run charges none. The scoring script is `qa-score.mjs`; it reads only the recorded result files.

02 Defects closed since the last report

10 of 10 · each re-verified against the running system

Nothing here is marked closed on the strength of a commit message. Each was re-tested the way it was found — a header read off a live response, a role read off a real sign-in, a guard read off the route file and then probed as the role that used to get through. F3 through F6 shared one root cause, a `POST` asserting a capability directly above a `GET` that did not, and were fixed together.

- F1** **Closed** **No security response headers except HSTS**

Six headers now ship on every response. `Content-Security-Policy: frame-ancestors 'self'` and `X-Frame-Options: SAMEORIGIN` close the framing hole on the login and invigilation screens; `Permissions-Policy` names the camera and microphone proctoring depends on and denies the rest; `X-Content-Type-Options`, `Referrer-Policy` and a two-year preloaded HSTS complete it.

VERIFIED `curl -I` against the live origin: all six present
- F2** **Closed** **Demo faculty account seeded as an administrator**

The membership was reset. This matters beyond the account itself: ten browser specs use it as their faculty fixture, including the one asserting that revoking a capability from faculty yields a 403 — which an administrator can never demonstrate, so that suite was passing without testing what it claimed.

VERIFIED Live sign-in as `faculty@demo.onyx` returns `role: faculty` in ABC Institution
- F3** **Closed** **Fee structures readable by faculty and exams**

The GET was guarded by the registry role set while its own capability, `fees.structures`, is declared never-delegable. It is now `requireOnyxRole('admin')` followed by the capability assertion, matching the POST beside it.

VERIFIED `campus.routes.ts:805` — `admin` + `assertCan`
- F4** **Closed** **Merchant configuration readable beyond administrators**

The route's docstring said "Administrators only" and the guard said otherwise. Now `admin` plus `fees.gateways`. The separate `/api/onyx/gateways` stays open to any signed-in role, correctly: it returns identifier, title and currency for the gateways an institution has switched on, and anybody who can be asked to pay needs it.

VERIFIED `campus.routes.ts:933` — `admin` + `assertCan`
- F5** **Closed** **Teaching-load allocations had no role guard at all**

The GET required only a session, then returned the institution's allocations unfiltered — reachable by guardian and employer. It now requires the registry roles, and the examinations office is answered with its own correctly-scoped set rather than everyone's.

VERIFIED `campus.routes.ts:170` — `requireOnyxRole(...REGISTRY)`
- F6** **Closed** **Placement drives readable by every role except the filtered one**

The service scoped its query for `employer` and for no other role, so students, guardians and the exams office received the full drive list. A student now receives 403.

VERIFIED Live read as `student@demo.onyx`: "This action is unauthorized."

F7	Closed	"All question banks" back-link was dead <code>/onyx/banks</code> has no index page, and Next prefetched the link, so the console errored on load before anyone clicked. The link is gone; a grep for anything pointing at that path now returns nothing. VERIFIED No reference to <code>/onyx/banks</code> remains in the app
F8	Closed	Score denominators failed minimum contrast The shared <code>Score</code> component rendered its denominator at <code>opacity-70</code> over a tinted band, below AA — inherited by every marks table in the product. Twelve pages across five roles now scan clean. VERIFIED axe: 12 pages, 0 serious or critical
F10	Closed	Examinations calendar rendered a future sitting as past The branch fired on <code>status === 'completed'</code> regardless of date — and publishing marks is what sets that status — then <code>Math.abs()</code> discarded the sign, so an exam three days ahead read "3 days ago · sat Wed, Aug 26" under "Examinations already sat". VERIFIED <code>onyx/exams/page.tsx</code> — the sign is now carried, not discarded
F11	Closed	A learner's own results identified examinations by database ID The Grades section — labelled "Your official record" — showed Exam #125 while the Assessments section above it showed real titles, because <code>marksFor()</code> never joined the exams table. A guardian saw the correct title on the same mark. The title is now resolved, with the id kept only as a fallback for an exam that has been deleted. VERIFIED <code>results/page.tsx</code> and <code>profile/page.tsx</code> — <code>m.exam?.title</code>

03 Still open

2 · neither a fault in the software

Both are housekeeping. They are listed at the same weight as a defect because a report that quietly drops what it cannot score is not a report.

F9	Housekeeping	Test-suite institutions and fixtures live in production The live database carries institutions created by automated runs — <code>authoring-college-mt5yk4vh</code> (471) predates this engagement, and each certification run adds a disposable <code>QA Certification College</code>. ABC Institution also now holds coding problems, papers and examinations prefixed <code>E2E</code>, <code>UI</code> and <code>QA</code> from the flow drivers. None is reachable by a real learner and none affects a score, but a demonstration tenant reads better without them. FIX Delete tenants 471, 477, 478, 754, 755 and the prefixed rows in ABC once confirmed disposable
F12	Housekeeping	Sign-up's password field is not exercised end to end Registration puts the password on step two, behind a code emailed to an organisation address, so a headless run cannot reach it without a mailbox. The field is the same component proven on both sign-in doors and on the administrator's add-a-person form; what is unverified is only that step of the registration flow, not the control. FIX Needs a mail sink in the QA environment

The area table above cuts the same checks by subject. This one cuts them by person: every phase that records who was signed in is re-bucketed by that account, so a reader asking whether the examinations officer's product is sound can answer it without reassembling four sections. Phases that are not role-scoped — the accessibility scan, the response headers, page timings — are absent here rather than attributed to a role they do not belong to.

ROLE	SCORE	%	CHECKS	GRADE
Student Catalogue, course and lesson reading, Code Lab practice and hand-in, sitting a paper, results, timetable, resume, fees, mobile layout		100%	106/106	A+
Faculty Course and lesson authoring, question bank, paper composition and publication, marking, release, cohort and item analytics, workspace review		100%	69/69	A+
Examinations office Halls, scheduling, seating allocation, mark entry, moderation, publication, invigilation queue		100%	71/71	A+
Placement office Employers, drives, rounds, interviews, contests, certificates		100%	60/60	A+
Employer Job posts, applications and interviews — and refusal everywhere else		100%	52/52	A+
Parent or guardian The linked child record: attendance, results and fees as shared, and nothing beyond what consent covers		100%	55/55	A+
Administrator Programmes, semesters, members, courses, enrolment, permissions, finance, settings, audit log, Code Lab bank, practice and workspace monitoring		100%	91/91	A+
Platform operator Institutions, operators, OAuth clients, platform audit, and every per-tenant console section including Code Lab and Practice activity		100%	35/35	A+

What "as that role" means. Not a page render under a session, but the work: the examinations officer allocated seating across a 5×6 hall and entered marks for three candidates; faculty composed a paper from a bank, marked a script 19/20 and released it; the student sat that paper, wrote a program against a hidden test suite and read the mark back; the guardian saw one child's record and nothing outside consent; the employer was refused everywhere except their own posts. The platform operator built the institution all of it happened in.

What was actually driven, and by which phase. The counts elsewhere in this document are read out of the recorded result files; this table is curated, because no result file knows what a feature is called. Where a row names a driver rather than a numbered phase, that driver is a script in the repository and can be re-run against any environment.

AREA	EXERCISED	DRIVEN BY
Identity	Sign-in for eight roles, two doors, wrong-door refusal, open-redirect, cookie flags, token tampering, sign-out	Phase 01, 09
Registration	Organisation-email sign-up, personal-domain refusal, emailed code, roll number	Phase 01 (step one)
Password entry	Show/hide on both sign-in doors, sign-up, change-password, add-a-person and the three console forms that set a password for somebody else	qa-password-toggle
Institutions	Provisioning, suspension, plan, domains, settings, deletion	Phase 07, 12
People	Members of every role, roll numbers, invitation, edit, removal, per-person permissions	Phase 12, 13
Permissions	Capability matrix by role and by name, delegation limits, revocation	Phase 03, 05
Programmes & semesters	Programme, semester, batch, allocation of teaching load	Phase 12
Courses	Create, edit, publish, catalogue, self-enrol, locked/paid access, roster, withdrawal	Phase 12, 13, qa-superadmin-to-student
Lessons	Modules, eleven lesson types, ordering, media upload, preview, progress	Phase 12, 13, 14
Live classes	Scheduling, banner, price, registration, console authoring	Phase 02, 07
Question banks	Banks, six question types including code, versioning, retirement	Phase 12, qa-inline-problem-bank
Assessments	Composition from banks, sections, publication, window, attempts, autosave, submission	Phase 12, 14
Marking & release	Auto-marking, manual marking, grade change, release, cohort and item analytics	Phase 12
Examinations	Scheduling without a semester, halls, seating, mark entry, moderation, publication	Phase 12, qa-superadmin-to-student
Proctoring	Consent, device checks, integrity events, invigilation queue	Phase 12, 02
Code Lab — authoring	Problem bank from both consoles, statement, test cases, hidden cases, weights, limits, publish and unpublish	qa-inline-problem, qa-inline-problem-bank
Code Lab — coding questions	A coding question written inside the paper, in the console and in the institution's own bank, created→keyed→published before the bank is touched	qa-inline-problem ×2

AREA	EXERCISED	DRIVEN BY
Code Lab — grading	Queued submission, sandbox execution, hidden-case scoring, partial marks, answer-key confidentiality	qa-superadmin-to-student
Code Lab — monitoring	Cohort submission feed filtered by learner, problem, course, state, language, kind and date; workspace monitor filtered by owner, course and language	qa-superadmin-to-student
Workspaces	Multi-file projects, snapshots, restore, run, review comments, staff oversight	Phase 02 , qa-superadmin-to-student
Results	Learner record, assessments and grades tabs, guardian view, transcripts, certificates	Phase 14 , 12
Attendance	Sessions, QR check-in, registers, present/late/excused arithmetic	Phase 02 , 05
Timetable & calendar	Slots, clash detection, publication, the week a candidate sees	Phase 02 , 12
Fees & finance	Heads, structures, invoices, outstanding, receipts, gateways, checkout	Phase 02 , 05
Placement	Employers, drives, rounds, jobs, applications, interviews, contests	Phase 02 , 03 , 05
Engagement	Discussions, mentor queue, support tickets, notifications, inbox	Phase 02 , 06
Guardian	Linked child, consent flags, attendance, results and fees as shared	Phase 08 , 12
Audit	Institution log and platform log, scoping, filters, lifecycle coverage	Phase 09 , 12
Error handling	A missing or foreign record answers not-found; a genuine fault renders a page with a reference, not a raw digest	Phase 02 , 06
Accessibility	axe scan across twelve pages and five roles	Phase 10
Mobile	No horizontal overflow at 390px, bottom tab bar	Phase 09

A defect list read alone gives no sense of what survived. These are the properties that were actively attacked and did not give way.

Multi-tenant isolation

Object IDs harvested from each tenant as its own admin, then requested from the other tenant's session in both directions across courses, members, assessments, exams, programmes and jobs.

59 attempts → 0 leaks, all clean 404 (never 403)

Write authorization

Seven escalation writes from each of six low-privilege roles: create an admin, escalate own membership, create a course, delete a member, patch tenant settings, award a skill, publish the timetable.

42 attempts → 0 breaches · 89×403, 12×404, 1×422

Session security

Cookie flags, token visibility from JavaScript, signature tampering and sign-out.

HttpOnly + Secure + SameSite=Lax · document.cookie empty · tampered and signed-out cookies both 401

Examination integrity

Proved by running a real paper: staff see the answer key, the candidate's own view of the same questions does not; drafts are invisible; results stay hidden until released.

4 of 4 confidentiality properties held

Guardian consent

The family view checked against the sharing flags on the child record.

attendance and results shown · fees "Not shared" · coursework, messages, applications, support all "Never"

Runtime stability

Roughly 220 authenticated page loads across every role, both consoles and three institutions.

0 × 5xx · 0 unhandled exceptions · 0 error boundaries

Code Lab

A problem opened, a solution typed into the Monaco editor, run, submitted, then read back from the API.

editor mounts · Run and Submit judge · submission persisted with score and status

Performance

Six administrator pages, cold navigation, Singapore region.

TTFB 31–139 ms · load 615–1202 ms

A throwaway institution — `qa-cert-90933141`, tenant 755 — was created for this, so no mutation touched the demo tenants. The chain below ran through the API and was then re-verified on the actual screens as each actor.

ACTOR	STEP	RESULT
SUPERADMIN	Create the institution and its first administrator	tenant 755, audited
ADMIN	Programme, semester, and six member accounts	roster = 6
ADMIN	Course QE101, two modules, four lessons, faculty assigned	course 486
ADMIN	Publish the course and enrol three learners	roster = 3 enrolled
FACULTY	Question bank and four questions with answer keys	bank 174
FACULTY	Assessment drawing four from the bank, previewed	assessment 236
STUDENT	Draft paper is not visible	not listed ✓
FACULTY	Publish the assessment	"Published."
STUDENT	Start the attempt; candidate view withholds the key	4 questions, no answer field ✓
STUDENT	Four answers autosaved, paper handed in	status = submitted
FACULTY	Marking queue, paper with responses, marked	score 19 / 20
STUDENT	Result hidden before release	0 rows ✓
FACULTY	Release results; cohort analytics and item analysis	mean 19, pass rate 100%
STUDENT	Released result visible	19/20, Passed
EXAMS	Hall created, examination scheduled, seating allocated	exam 260, 3 seated
EXAMS	Marks entered for three candidates	78 / 55 / 34
STUDENT	Exam mark hidden before publication	0 rows ✓
EXAMS	Publish examination marks	released
STUDENT	Examination result visible	78, grade Pass
ADMIN	Audit log recorded the whole chain unprompted	9 distinct actions

Cleanup this run owes you. This lifecycle built institution 755 (`qa-cert-90933141`), and earlier certification runs left `qa-cert-00701173` (477), `qa-cert-00810765` (478), `authoring-college-mt5yk4vh` (471) and one earlier lifecycle tenant behind. ABC Institution additionally holds coding problems, papers and examinations prefixed `E2E`, `UI` and `QA`, written by the flow drivers. None is reachable by a real learner; all are safe to delete. Filed as F9.

- **A clean sweep is not proof of absence.** Every check in this report passed, which says the properties tested hold — not that nothing else is wrong. The value is in what was attacked, itemised in §6, and in what was deliberately not, below.
- **Sign-up's password step was not driven.** Registration puts it behind a code emailed to an organisation address, which a headless run cannot read. The field is the same component proven on both sign-in doors; the unverified part is that step of registration. Filed as F12.
- **Proctoring was exercised only as far as its queue.** The invigilation console and the proctor queue respond, but no camera or screen-share session was driven.
- **Payments were not exercised.** No gateway is configured in any tenant, so checkout, invoicing and reconciliation are untested beyond their authorization guards.
- **Load and concurrency were not tested.** The timings are single-user cold navigations, not a benchmark.
- **The lifecycle covered one learner sitting one paper.** Multi-attempt, second marking, moderation, anonymous marking and transcript issue were not driven.
- **Accessibility was automated only.** axe on 12 pages; no keyboard-only or screen-reader walkthrough, and axe catches a minority of real barriers.

Onyx LMS · end-to-end QA certification · 24 Aug 2026 · target <https://onyx-lms-v2.vercel.app> · build 70e73f7
732 automated checks + 12 axe page scans · harness qa-lib.mjs and qa-01...qa-14 · scoring qa-score.mjs · evidence qa-results-*.json
Companion markdown, generated from the same run: QA-REPORT-2026-08-24.md